TP MITM (Man In The Middle) SSH

Q1. Pourquoi l'accès aux machines virtuelles par la console ou l'interface graphique n'est pas possible avec le super-administrateur root ?

Pour éviter que n'importe qui essaye de trouver un moyen d'accès aux machines virtuelles pour assurer la sécurité.

Q2. Expliquer à quoi sert la commande sudo et quels avantages a-t-elle sur l'utilisation de la commande su - ?

La commande permet de passer en super utilisateur ce qui signifie qu'elle aura accès à tous les répertoires et commandes qu'elle souhaite donc modifier des programmes, créer des répertoires ou des fichiers etc. Ces avantages sont qu'elle permet de passer outre les droits qu'on possède si on est un utilisateur lambda.

Q3. Quelles commandes permettent de savoir si le service OpenSSH (serveur) est déjà installé et démarré ?

Pour voir si le service OpenSSH est installé et démarré on peut exécuter la commande systemctl status openssh et là on verra si OpenSSH est démarré ou non

Q4. Indiquer le répertoire où sont stockées les clés publique et privée créées ainsi que le positionnement des permissions appliquées sur les fichiers correspondants. Puis indiquer quel est le fichier de configuration du service SSH

Le répertoire où sont stockées les clés publique et privée est « /etc/ssh », le fichier de configuration du service SSH est ssh_config.

Q5. Que signifie cette alerte qui est affichée à l'écran ? Devez-vous continuer l'opération ? Pourquoi ?

L'alerte à l'écran signifie qu'on cherche à chiffrer l'échange entre le client et le serveur ssh. Oui on doit continuer l'opération pour pouvoir effectuer la demande SSH et afin de chiffrer la connexion pour éviter la traçabilité.

Q6. Lors d'une prochaine connexion depuis le même client sur ce serveur, ce message apparaîtra-t-il à nouveau ? Pourquoi ?

Non il réapparaît pas car il a déjà initié l'échange entre le client et le serveur par une clé de chiffrement SHA256.

Q7. Sur la machine virtuelle cliente, expliquer à quoi sert le fichier /home/etusio/.ssh/known_host.

Fichier contenant les clés d'hôtes des serveurs SSH auxquelles l'utilisateur a accédé. Ce fichier est très important car il permet de garantir que le client SSH se connecte au bon serveur SSH.

Q8. Indiquer quelles sont les informations que peut obtenir un attaquant grâce à ces commandes ?

Il peut avoir les ports qui sont ouverts, les protocoles et versions utilisés pour pouvoir baser son attaque.

TP MITM (Man In The Middle) SSH

Q9. Expliquer les principes généraux d'une attaque de l'homme du milieu (Man in the Middle).

C'est une attaque qui permet d'intercepter les communications entre deux personnes, sans qu'aucune ne puisse se douter que le canal de communication a été compromis. Particulièrement dans la méthode d'échange de clés Diffie-Hellman.

Q10.Noter les associations adresse IP / adresse MAC présentes sur les deux machines. Sont-elles cohérentes ?

Nous avons 3 IP sur la VM Serveur celle en 192.168.56.12 et 192.168.56.11 92.168.56.254 et sur la VM Cliente nous avons 192.168.56.10 et 192.168.56.12. L'adresse MAC de l'ip 192.168.56.12 est cohérente sur les deux VM.

Q11.Pourquoi l'activation du routage sur la machine de l'attaquant est indispensable au bon fonctionnement de l'attaque MITM ?

L'activation du routage permet entre la machine cliente et le serveur d'avoir le routeur pour pouvoir interférer entre eux.

Q12.Pourquoi cette redirection de ports est indispensable au succès de l'attaque de l'homme du milieu ?

Parce que le client croit parler au serveur sur port 22 et l'attaquant intercepte sur port 22, puis redirige vers port 2222 où écoute ssh-mitm. Cela permet d'intercepter les identifiants.

Q13.Indiquer en quoi une attaque de type ARP Spoofing peut être utile ici au pirate ?

Elle peut être utile au pirate pour pouvoir se faire passer pour un équipement dont l'adresse MAC est déjà connu du service informatique pour qu'on ne se pose pas de question à son sujet.

Q14.Comparer les caches ARP du client et du serveur avec les associations notées précédemment lors de la question 10. Qu'en concluez-vous ?

Les adresses MAC ont été remplacées par la MAC de l'attaquant. Le trafic est désormais intercepté par la VM kali.

```
etusio@clissh:~$ ip neigh show
192.168.56.10 dev enp0s3 lladdr 08:00:27:7f:f9:eb STALE
192.168.56.12 dev enp0s3 lladdr 08:00:27:27:cc:2d STALE
etusio@clissh:~$ ip neigh show
192.168.56.254 dev enp0s3 lladdr 08:00:27:09:d1:0e STALE
192.168.56.10 dev enp0s3 lladdr 08:00:27:27:cc:2d REACHABLE
192.168.56.12 dev enp0s3 lladdr 08:00:27:27:cc:2d STALE
```

```
etusio@srvssh:~$ ip neigh show
192.168.56.12 dev enp0s3 lladdr 08:00:27:27:cc:2d STALE
192.168.56.254 dev enp0s3 lladdr 08:00:27:09:d1:0e DELAY
192.168.56.11 dev enp0s3 lladdr 08:00:27:5b:84:c2 STALE
etusio@srvssh:~$ [ 3236.177138] e1000 0000:00:03.0 enp0s3: Reset adapter

etusio@srvssh:~$ ip neigh show
192.168.56.12 dev enp0s3 lladdr 08:00:27:27:cc:2d STALE
192.168.56.254 dev enp0s3 lladdr 08:00:27:09:d1:0e STALE
192.168.56.11 dev enp0s3 lladdr 08:00:27:27:cc:2d REACHABLE
```

Q15.À partir de ces différentes observations, expliquer en détails comment fonctionne une attaque ARP Spoofing.

D'abord l'attaquant envoie de fausses réponses ARP aux victimes. Puis les victimes mettent à jour leurs caches ARP avec de mauvaises associations IP et adresse MAC. Enfin le vrai trafic passe par l'attaquant.

Q16.Envoyer une requête ping (icmp-écho) depuis le client vers le serveur (192.168.56.10). Puis vérifier à l'aide d'une capture de trame sur la machine Kali Linux que ces dernières passent effectivement bien par l'attaquant. Quels éléments démontrent que l'attaque se déroule correctement ?

La machine kali reçoit ceci :

```
Thu Dec  4 13:52:52 2025 [549454]
  192.168.56.11:0 ⟶ 192.168.56.10:0 | P (0)

Thu Dec  4 13:52:52 2025 [555984]
  192.168.56.10:0 ⟶ 192.168.56.11:0 |  (0)

Thu Dec  4 13:52:53 2025 [550831]
  192.168.56.11:0 ⟶ 192.168.56.10:0 | P (0)

Thu Dec  4 13:52:53 2025 [556080]
  192.168.56.10:0 ⟶ 192.168.56.11:0 |  (0)

Thu Dec  4 13:52:54 2025 [552341]
  192.168.56.11:0 ⟶ 192.168.56.10:0 | P (0)
```

Le ping a pour destination l'ip du serveur mais il est associé à l'adresse MAC de l'attaquant. On analyse la trame directement avec Wireshark.

Q17.Recopier la ligne qui contient le login et le mot de passe capturés dans le fichier /var/log/auth.log.

Dec 4 14:01:40 kali sshd_mitm[11139]: INTERCEPTED PASSWORD: hostname: [192.168.56.10]; username: [etusio]; password: [Fghijkl1234*] [preauth]

Q18.Que contient le fichier /home/ssh-mitm/shell_session_0.txt présent sur Kali Linux ? NB : L'accès à ce fichier nécessite l'utilisation de la commande sudo.

Ce fichier contient la session SSH du client interceptée par l'attaquant donc nous pouvons voir l'ensemble des commandes exécuter par l'attaquant.

Q19.Expliquer pourquoi ce message d'erreur apparaît ?

Ce message apparaît car la clé publique du serveur a changé et le serveur nous indique une possible attaque MITM.

Q20.Proposer une solution afin de pouvoir à nouveau se connecter au service SSH depuis le client.

Il faut supprimer le contenu du fichier Known_hosts : echo >~/.ssh/known_hosts

Q21.Pourquoi l'algorithme ECDSA a été préféré à l'algorithme RSA lors de la génération de la paire de clés ?

ECDSA a été préférée car les deux algorithmes ont la même sécurité mais ECDSA a une clé de plus petite taille.

Q22.A votre avis, pourquoi la mise en place de cette phrase de chiffrement pour accéder à la clé privée est extrêmement importante ?

La phrase de chiffrement permet de sécuriser l'accès à la clé privée. Elle permet une sécurité plus grande puisque la clé privée est protégée par deux éléments.

Q23.Lister le contenu du répertoire $HOME/.ssh/ puis afficher le contenu du fichier id_ecdsa.pub.

Contenu du répertoire :

```
etusio@clissh:~$ ls $HOME//.ssh/
id_ecdsa  id_ecdsa.pub  known_hosts
```

Contenu du fichier id_ecdsa.pub

```
etusio@clissh:~$ cat $HOME//.ssh/id_ecdsa.pub
ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBOjs+/dSVVauIYsthNX75iDpc1pvB049/6BbDUp6oJ71oqeO5oJSC6t3MWm/uo/uf8TA7t
QlaCaAVXhAW8UkKAo= etusio@clissh
```

TP MITM (Man In The Middle) SSH

Q24.Sur la machine cliente clissh.local.sio.fr, modifier les droits du fichier ~/.ssh/id_ecdsa (droits initiaux : 600 etusio:etusio) qui contient votre clé privée en 644. Se connecter sur le serveur distant srvssh.local.sio.fr qui contient la clé publique. Que se passe-t-il ? Pourquoi ?

La connexion est refusée car la clé privée est accessible en écriture par le groupe etusio et par l'ensemble des autres utilisateurs. Donc la clé n'est pas du tout protéger.

Q25.Rétablir les droits de ~/.ssh/id_ecdsa sur le poste client. Maintenant sur le serveur distant, afficher les droits d'accès appliqués au fichier ~/.ssh/authorized_keys.

-Rw- - - - - - - etusio etusio ⇒ Seulement l'utilisateur etusio a le droit de lecture et d'écriture sur le fichier authorized_keys.

Q26.Puis, modifier les droits de ~/.ssh/authorized_keys en 666. Se déconnecter puis se reconnecter. Vérifier si un changement est apparu ou non et tenter d'expliquer pourquoi (ne pas oublier de rétablir les droits d'origine ensuite).

Toujours le problème de permission denied. Le droit 666 ne permet pas de sécuriser le fichier.

Q27.En analysant la connexion par clés, proposer une hypothèse de fonctionnement de cette nouvelle forme d'authentification. Expliquer ce qui différencie une connexion par mot de passe d'une connexion par clé de chiffrement.

L'authentification par clé utilise la cryptographie asymétrique, où la clé publique est partagée et la clé privée reste secrète, différant d'une authentification par mot de passe qui repose uniquement sur une information secrète.

Q28.Suite à la mise en place de cette authentification par clés de chiffrement, tenter à nouveau de simuler une attaque MITM entre le client et le serveur SSH. Quel résultat obtenez-vous ? Pourquoi ?

La connexion ssh échoue puisque la clé n'est pas interceptée comme grâce à ssh-agent elle n'est pas transmise, la clée est cryptée sur la machine attaquante kali.

Q29.Expliquer l'intérêt de cette démarche.

L'intérêt de cette démarche est que notre clé privée n'est pas transmise au serveur, elle reste sur notre machine. Le transfert d'agent SSH permet à un serveur distant d'utiliser la clé SSH de la machine cliente sans que ces clés ne soient copiées sur le serveur.

TP MITM (Man In The Middle) SSH

Q30.Mettre en œuvre les préconisations suivantes tirées des recommandations pour un usage sécurisé de SSH publié par l'ANSSI :
1.Vérifier que les clés privées de chiffrement présentes dans le répertoire /etc/ssh/ appartiennent à l'utilisateur root en lecture-écriture seulement ;
2. S'assurer que c'est bien la version 2 du protocole SSH qui est utilisée ;
3. Le serveur SSH doit dorénavant écouter sur le port 222/TCP ;
4. Vérifier que les droits sur les fichiers sont appliqués de manière stricte par SSH ;
5. L'accès SSH par l'utilisateur root doit être interdite ;
6. Mettre en œuvre une séparation des privilèges à l'aide d'un bac à sable (sandbox) ;
7. L'accès à distance par des comptes ne disposant pas de mot de passe doit être interdit ;
8. Autoriser 3 tentatives de connexion successives en cas d'erreur dans le mot de passe;
9. Le service doit afficher les informations de dernière connexion à l'utilisateur quand il se connecte ;
10. N'autoriser que l'utilisateur etusio à se connecter sur le serveur.
Le lien suivant liste les différentes directives qui existent dans le fichier sshd_config :
[sshd_config(5) - OpenBSD manual pages]

1. Clés privées root: 600 root:root
2. SSH v2 : Protocol 2
3. Port SSH : Port 222
4. Vérification stricte : StrictModes yes
5. Interdire root : PermitRootLogin no
6. Sandbox : UsePrivilegeSeparation sandbox
7. Interdire comptes sans mot de passe : PermitEmptyPasswords no
8. Limiter essais : MaxAuthTries 3
9. Afficher dernière connexion : PrintLastLog yes
10. Autoriser uniquement etusio : AllowUsers etusio

Q31.Expliquer dans une définition succincte ce qu'est l'état de l'art dans le domaine de la cybersécurité.
L'état de l'art est l'ensemble des pratiques et technologies les plus avancées et éprouvées dans le domaine.

Q32.Définir ce qu'est le principe de Kerckhoffs

La sécurité d'un système cryptographique dépend uniquement du secret de la clé et non du secret de l'algorithme.

Q33.Selon ce principe, pourquoi est-il pertinent de choisir des algorithmes cryptographiques connus et respectant l'état de l'art ?

Les algorithmes connus et étudiés sont moins susceptibles de contenir des vulnérabilités, offrant une sécurité plus fiable que des algorithmes non testés (qui pourraient être dangereux).